

Security+ 2.4 · Cryptographic Attacks

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — Cryptographic Attacks (9:31)**

· [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Downgrade attack: convence as partes a usar protocolo FRACA (SSL strip: HTTPS→HTTP); hash collision (2 textos, mesmo hash — MD5 morreu por collision); brute force da chave. Defesa: HSTS (browser NUNCA aceita downgrade pra HTTP), patch crypto, algoritmo atual (TLS 1.3).

Highlights que a prova cobra

- Downgrade: convence pra usar versão FRACA (SSL stripping)
- HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip
- Collision MD5/SHA-1: dois textos, mesmo hash — abandonados

Dicas de prova & Cenários Típicos

- 'forces a connection to a weaker protocol' = downgrade attack
- 'prevents downgrade to HTTP' = HSTS

Cenário clássico de exame: Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP (sem TLS)' = SSL stripping; defesa: HSTS.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.4 — Cryptographic Attacks)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

2. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

3. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Downgrade: convence pra usar versão FRACA (SSL stripping)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA (SSL stripping)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Collision MD5/SHA-1: dois textos, mesmo hash — abandonados'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Collision MD5/SHA-1: dois textos, mesmo hash — abandonados...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'forces a connection to a weaker protocol' = downgrade attack'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'forces a connection to a weaker protocol' = downgrade attack...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'prevents downgrade to HTTP' = HSTS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'prevents downgrade to HTTP' = HSTS...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP (sem TLS)' = SSL stripping; defesa: HSTS.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Downgrade: convence pra usar versão FRACA (SSL stripping)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA (SSL stripping)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Hash com salt (ex: bcrypt).

✓ **Por que está certa:** O armazenamento seguro de senhas de usuários exige o uso de funções de hash criptográfico lentas e resistentes a ataques de força bruta, como bcrypt, scrypt ou Argon2, combinadas com um salt único e aleatório por usuário. O salt impede ataques de tabela pré-computada (rainbow tables) e garante que senhas iguais produzam hashes diferentes. Funções como bcrypt são projetadas para serem computacionalmente custosas, ajustáveis por fator de custo, dificultando ataques de dicionário e força bruta offline. O hash é unidirecional, então mesmo que o banco de dados seja comprometido, o atacante não obtém a senha original diretamente, apenas o hash, que deve ser quebrado individualmente.

✗ **Por que as outras estão erradas:**

- *Criptografia AES reversível:* AES é uma cifra simétrica reversível: com a chave correta, o texto cifrado pode ser decifrado de volta ao texto claro. Se as senhas forem armazenadas cifradas com AES, qualquer pessoa que obtenha a chave de criptografia (por exemplo, através de comprometimento do servidor de aplicação ou do banco de dados) pode recuperar todas as senhas originais. Isso viola o princípio de que nem mesmo os administradores do sistema devem conhecer as senhas dos usuários. Além disso, a gestão da chave AES adiciona complexidade e risco desnecessários para um dado que nunca precisa ser recuperado em texto claro.
- *Texto claro protegido por firewall:* Armazenar senhas em texto claro significa que elas estão legíveis no banco de dados ou arquivo de configuração. Um firewall protege contra acessos não autorizados pela rede, mas não impede que um atacante que explore uma vulnerabilidade na aplicação, um insider malicioso ou um administrador com acesso ao banco de dados leia diretamente as senhas. A segurança em profundidade exige que o dado sensível seja protegido em repouso, independentemente de controles perimetrais. Firewall é um controle de rede, não de armazenamento de credenciais.
- *Base64:* Base64 é uma codificação reversível sem chave, frequentemente usada para representar dados binários em texto. Não oferece confidencialidade alguma: qualquer pessoa pode decodificar uma string Base64 instantaneamente. Armazenar senhas em Base64 é funcionalmente equivalente a armazená-las em texto claro, apenas com uma aparência ofuscada. Não há salt, não há custo computacional e não há resistência a ataques. É uma prática completamente inadequada para proteção de credenciais.

2) B — É de mão única (não reversível).

✓ **Por que está certa:** Uma característica fundamental das funções hash criptográficas é serem de mão única (one-way), ou seja, não reversíveis. Isso significa que, a partir do hash, não é possível recuperar a mensagem original. Essa propriedade é conhecida como resistência à pré-imagem. Diferentemente da criptografia, que é reversível com a chave correta, o hash é projetado para ser irreversível. O CompTIA Security+ destaca que funções hash como SHA-256 são usadas para integridade e armazenamento de senhas (com salt), justamente porque não podem ser revertidas. A opção 'É de mão única (não reversível)' descreve corretamente essa característica essencial.

✗ **Por que as outras estão erradas:**

- *Pode ser revertido com a chave:* Essa é uma característica da criptografia simétrica ou assimétrica, não de funções hash. Na criptografia, a reversão é possível com a chave apropriada (simétrica) ou com a chave privada (assimétrica). Funções hash não possuem chave e não são projetadas para reversão. Portanto, essa afirmação está incorreta para hash. O CompTIA Security+ enfatiza que hash é unidirecional e não usa chaves, ao contrário da cifra.
- *Sempre encurta o texto pela metade:* Funções hash produzem uma saída de tamanho fixo,

independentemente do tamanho da entrada. Por exemplo, SHA-256 sempre gera 256 bits (32 bytes). Não há uma regra de 'encurtar pela metade'; o tamanho do digest é constante e definido pelo algoritmo. Além disso, a função hash não é uma compressão simples; ela deve ser resistente a colisões e pré-imagem. Essa afirmação é tecnicamente falsa e não descreve uma propriedade de hash.

- *Precisa de par de chaves:* Funções hash não utilizam chaves. Elas são algoritmos públicos e determinísticos que mapeiam dados de entrada para um resumo. O uso de par de chaves é característico de criptografia assimétrica (como RSA ou ECC), não de hash. Embora hashes possam ser usados em conjunto com chaves em HMAC, a função hash em si não requer chaves. Portanto, essa opção está incorreta.

3) B — Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA (SSL stripping)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Downgrade: convence pra usar versão FRACA (SSL stripping).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: Collision MD5/SHA-1: dois textos, mesmo hash — abandonados....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Collision MD5/SHA-1: dois textos, mesmo hash — abandonados.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: 'forces a connection to a weaker protocol' = downgrade attack....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): 'forces a connection to a weaker protocol' = downgrade attack.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: 'prevents downgrade to HTTP' = HSTS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): 'prevents downgrade to HTTP' = HSTS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP (sem TLS)' = SSL stripping; defesa: HSTS..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA (SSL stripping)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Downgrade: convence pra usar versão FRACA (SSL stripping).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.